

WIRELESS NETWORK AND SECURITY

Bluetooth Security and Privacy

Instructor: Jinsong Han



Bluetooth

- In the 2000s, the *age of the smartphone*, this figure rose to 2 billion.
- By 2021 there will be 48 billion devices connected to the internet, in what we're likely to term *the age of the IoT*.

48 BILLION

devices will be connected to the internet by the year 2021 — of those, **30%** are forecasted to include Bluetooth technology.



What is Bluetooth?

- Bluetooth is a wireless technology standard for exchanging data over short distances
 - ISM band from 2.4 to 2.485 GHz
 - fixed and mobile devices
 - building personal area networks(PANs)
- First proposed by telecom vendor Ericsson in 1994
- Originally conceived as a wireless alternative to RS-232 data cables

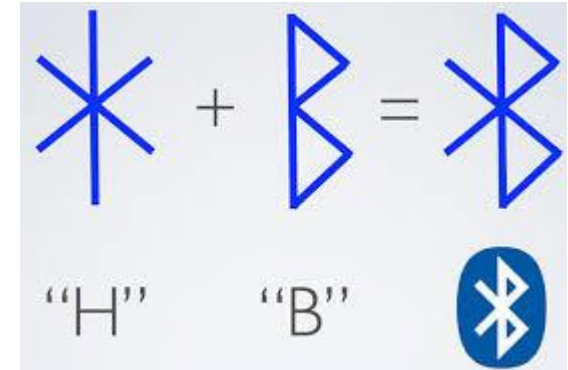


Bluetooth Special Interest Group

- Bluetooth is managed by the **Bluetooth Special Interest Group (SIG)**,
 - founded in 1998 by a group of companies
 - more than 20,000 member companies as of 2014
 - Bluetooth was standardized as **IEEE 802.15.1**, but the standard is no longer maintained.
- The SIG oversees the development of the specification, manages the qualification program, and protects the trademarks.

The Name: “Bluetooth”

- The 10th Century king of Denmark Harald "Bluetooth" Gormsson united all the tiny island around Denmark, southern Sweden, and southern Norway into a single country.
- He got his name from his penchant for blueberries.
- Bluetooth, the new low-cost radio technology, is designed to unite or connect all different types of devices to effectively work as one.



Bluetooth Applications

- Audio and data peripherals
 - Headsets, Speakers, ...
 - Keyboards, Cameras, Printers, ...
- Intelligent devices
 - Cellular phones, laptops, ...
- Embedded applications
 - Cars, Industrial systems, ...

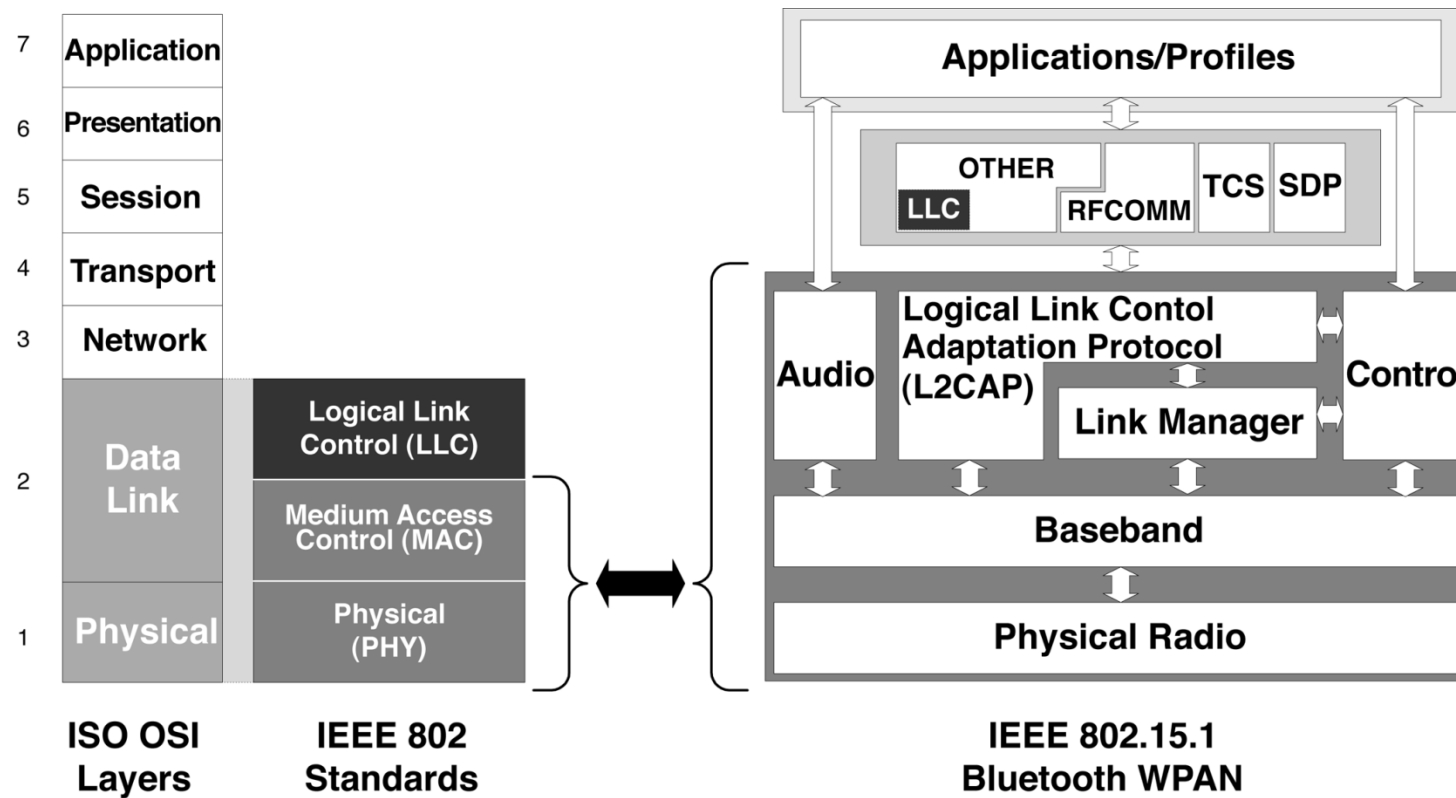


Bluetooth Characteristics

- Unlicensed 2.4 GHz radio band: ISM (industrial, scientific, medical) band – available worldwide
 - Gross data rate of 1 Mbit/s (EDR: 3Mbit/s, HS: 24Mbit/s)
 - Basic 10m range extended to 100m with amplifiers
 - TDMA-TDD-Slow Frequency Hopping spread spectrum
- Supports up to 8 devices in a piconet (1 master and 7 slaves)
 - Piconets can combine to form scatternets
- Mixed voice/data connections possible
- Encryption
- Ubiquitous radio link

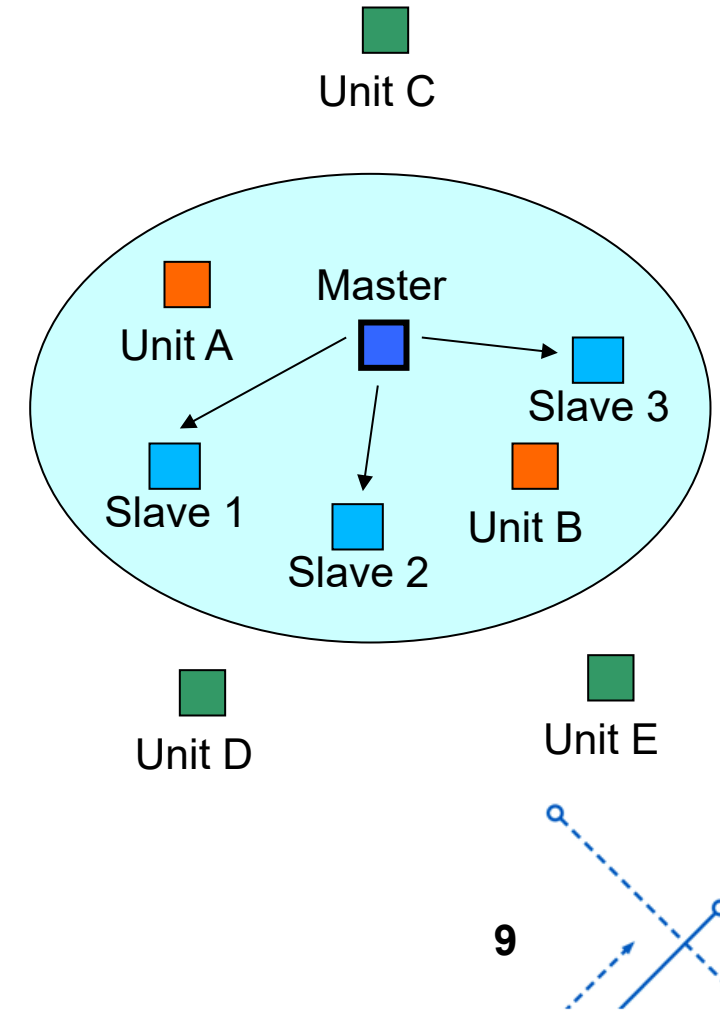


OSI and Bluetooth Protocol



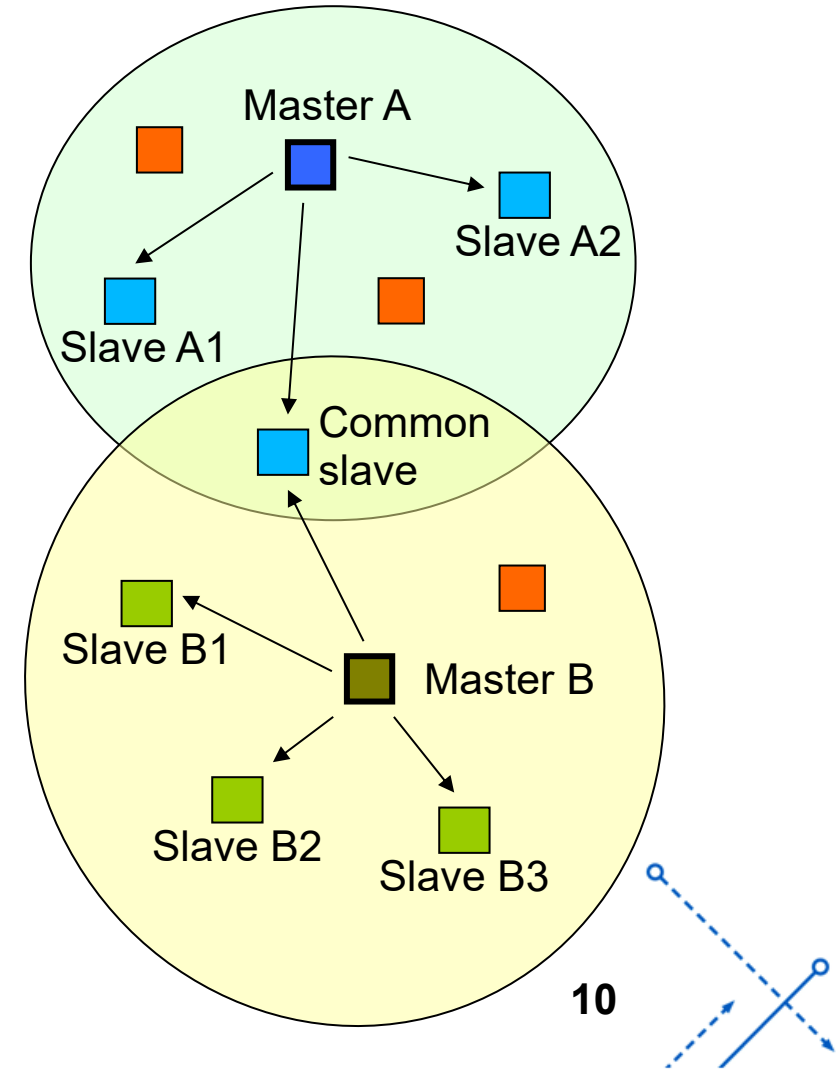
Communication Topology: Bluetooth Piconet

- Collection of devices connected in an ad hoc fashion
- One unit will act as master
 - Sets clock and frequency hopping pattern
 - Can connect to 7 active or 255 inactive (parked) slaves
 - Determines bit rate allocated to each slave
- Unique frequency hopping pattern/ID
- All devices synchronized to a common clock and hopping sequence.
- Slaves can communicate only with the master



Communication Topology: Bluetooth Scatternet

- A device may participate concurrently in two or more piconets on time-division multiplexing (TDM) basis.
- A device can be both master and slave.
- A device can never be a master of more than one piconet.
- Two or more piconets that include one or more devices participating in more than one piconet form a scatternet.



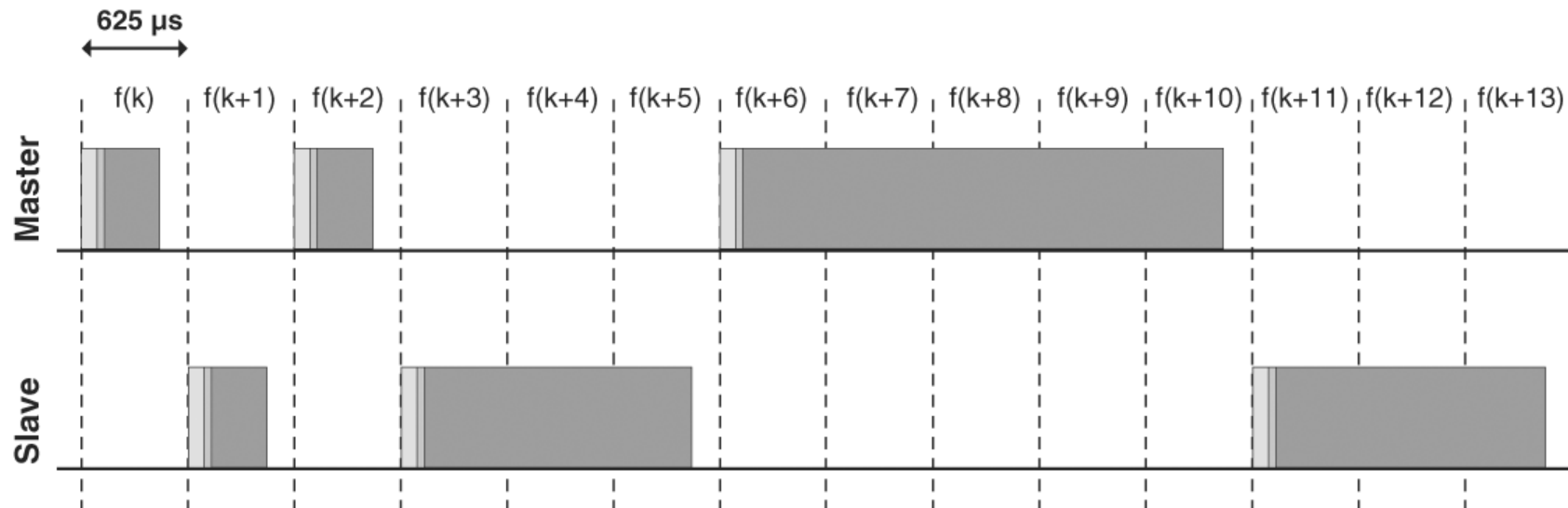
Physical Layer: Frequency Hopping

- When the piconet is established, the Master Clock (CLK) is communicated to the slaves.
- Devices in a piconet use a specific **frequency hopping pattern**, which is determined by fields in the device address and the clock of the master.
- The basic hopping pattern is a pseudo-random ordering of the 79 frequencies in the ISM band.
- Adaptive Frequency Hopping (AFH) is used to improve the performance of physical links in the presence of interference as well as reducing the interference caused by physical links on other devices in the ISM band.
 - AFH uses less than the full 79 frequencies that the basic piconet uses.



Physical Layer: Time Slots

- The basic piconet physical channel is divided into time slots, each 625 μs in length.
- A time division duplex (TDD) scheme is used where master and slave alternatively transmit.
- The packet start should be aligned with the slot start. Packets may extend over up to five time slots.



Recent History of Bluetooth

- The Bluetooth Special Interest Group (SIG) is taking care of current and future versions of this industry standard
- For Bluetooth v1.1 and Bluetooth v1.2 there has been a collaboration with IEEE802.15.1
 - IEEE Standards 802.15.1-2002 and 802.15.1-2005
- Afterwards the IEEE Study Group 802.15.1b voted unanimously to discontinue the relation to Bluetooth SIG
 - later versions of Bluetooth did not become IEEE standards
- Bluetooth v2.0 with optional Enhanced Data Rate (EDR) has been published in November 2004.
 - combination of GFSK and DPSK to increase data rate to 3Mbps
- Bluetooth v2.1 + EDR (July 2007)
 - Secure simple pairing protocol speeds up pairing procedure
- Bluetooth v3.0 + HS (high speed) published April 2009
 - alternate PHY based on WiFi used for high data rate (up to 24Mbps)
 - UWB Multiband was candidate PHY but was dropped due to IPR problems
 - Bluetooth PHY used for control channels and medium rate traffic
- Bluetooth Smart (v4.0) published June 2010: Classic Bluetooth, Bluetooth+HS and Bluetooth Low Energy
 - low energy protocol originates from the Wibree system (Nokia);
 - LE not compatible with other Bluetooth modes
- Bluetooth v5 (June 2016)
 - 2x the data rate, 4x the range, 8x the broadcast capability

Bluetooth Low Energy (BLE, Smart Bluetooth)

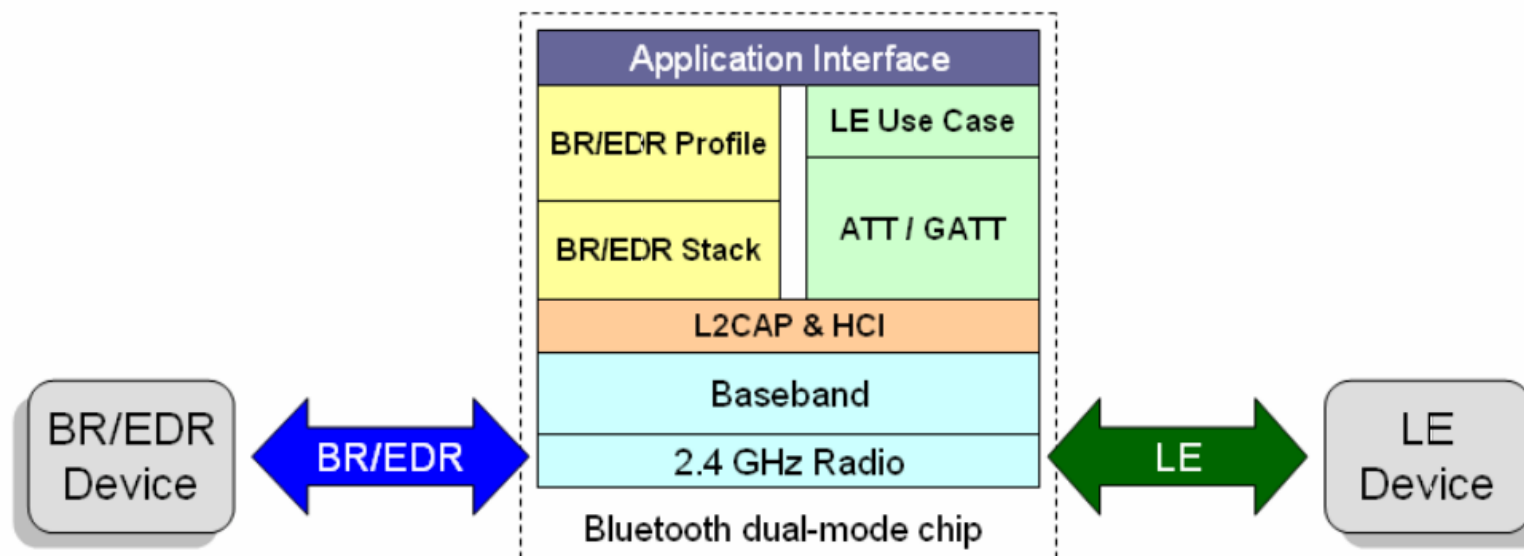
- New low power design, no downward compatibility to Classic Bluetooth (CB)
- To be used in sensor networks
 - sensors transmit short data packets with a low duty cycle
 - support low latency
 - not optimized for streaming data
 - asymmetric node complexity (slave - master)
- Reuse to as much as possible Classic Bluetooth hardware
- Simplified physical layer as compared to Classic Bluetooth
 - three advertising channels (CB uses 16 or 32 for Inquiry and Page) used for connection process
 - 37x2MHz data channels (CB: 79x1MHz)
 - increased modulation index of GMSK
- 3ms latency from nonconnected state (CB: >100ms)



Dual Mode Chipsets (Bluetooth Smart Ready)



Dual Mode Chipsets



Bluetooth's Dual-mode advantage. One chip supports all types device.

Classic Bluetooth Versus Bluetooth Smart

Technical Specification	Classic Bluetooth technology	Bluetooth Smart technology
Distance/Range (theoretical max.)	100 m (330 ft)	<100 m (<330 ft)
Over the air data rate	1–3 Mbit/s	1 Mbit/s
Application throughput	0.7–2.1 Mbit/s	0.27 Mbit/s
Active slaves	7	Not defined; implementation dependent
Security	56/128-bit and application layer user defined	128-bit AES with Counter Mode CBC-MAC and application layer user defined
Robustness	Adaptive fast frequency hopping, FEC, fast ACK	Adaptive frequency hopping, Lazy Acknowledgement, 24-bit CRC, 32-bit Message Integrity Check
Latency (from a non-connected state)	Typically 100 ms	6 ms
Total time to send data (det. battery life)	100 ms	3 ms
Voice capable	Yes	No
Network topology	Scatternet	Scatternet
Power consumption	1 W as the reference	0.01 to 0.5 W (depending on use case)
Peak current consumption	<30 mA	<15 mA
Service discovery	Yes	Yes
Profile concept	Yes	Yes

Bluetooth Security

- Authentication
 - Verifies the identification of the devices that are communicating in the channel.
- Confidentiality
 - Protecting the data from the attacker by allowing only authorized users to access the data.
- Authorization
 - Only authorized users have control over the resources.



Security Modes of Bluetooth

- Security Mode 1
 - Non-Secure Mode
- Security Mode 2
 - Service level enforced security mode
- Security Mode 3
 - Link-level enforced security mode



Mode 1: No Security

- Only security at this level is by the nature of the connection: data-hopping and short-distance
- Bluetooth devices transmit over the unlicensed 2.45GHz radio band, the same band used by microwave ovens and cordless phones.(FHSS)
- All Bluetooth devices employ “data-hopping”, which entails skipping around the radio band up to 1600 times per second, at 1MHz intervals (79 different frequencies)
- Most connections are less than 10 meters, so there is a limit as to eavesdropping possibilities



Mode 2: Service Level Security

- Service Access depends on device:
 - Trusted devices have unrestricted access to all services, fixed relationship to other devices
 - Untrusted devices generally have no permanent relationship and services that it has access to are limited.
- Unfortunately, all services on a device are given the same security policy, other than application layer add-ons.

Mode 2: Service Security Levels

- Services can have one of 3 security levels:
 - **Level 3:** Requires Authentication and Authorization. PIN number must be entered.
 - **Level 2:** Authentication only, fixed PIN ok.
 - **Level 1:** Open to all devices, the default level. Security for legacy applications, for example.



Mode 3: Link level security

- Security is implemented by symmetric keys in a challenge-response system.
- Security implementations in Bluetooth units are all the same, and are publicly available:
 - http://www.bluetooth.com/pdf/Bluetooth_11_Specifications_Book.pdf
- Critical ingredients
 - PIN, BD_ADDR, RAND(), Link and Encryption Keys



蓝牙安全运作流程

- **0x2 蓝牙的信任模式**
 - 受信任：设备已与另一设备建立固定关系，且对所有服务的访问不受限制。
 - 不受信任：虽然已成功通过身份验证，但设备只能访问一组受限制的服务。
- **0x3 设备的可发现性**
 - BD_ADDR
- **0x4 蓝牙安全服务**
 - 基于挑战/应答(Challenge/Response)方式执行身份验证。
 - PIN码/SSP
- **0x5 其他安全功能**
 - 自适应跳频
 - E0加密算法
 - 不可见性
 - 配对



Problems with the standard Bluetooth Security

Security Issue	Remarks
Strength of the Random Number Generator (RNG) is unknown.	RNG may produce periodic numbers that reduces the strength of authentication mechanism.
Short PINs are allowed.	Such weak PINs are used to generate link and encryption keys that are easily predictable.
Encryption key length is negotiable.	More robust initialization key generation procedure should be developed.
No user authentication exists.	As only device authentication is provided, application security and user authentication can be employed.
Stream cipher is weak and key length is negotiable.	Robust encryption procedure and minimum key length should be decided and passed as an agreement.

Problems with the standard Bluetooth Security (Cont'd)

Security Issue	Remarks
Privacy can be compromised if the BD_ADDR is captured and associated with a particular user.	Once the BD_ADDR is associated with a particular user, that user's activity can be logged. So, loss of privacy can be compromised.
Device authentication is simple shared key challenge response.	One-way authentication may be subjected to man-in-middle attacks. Mutual authentication is a good idea to provide verification.

Security Threats

- Denial of service
 - Makes the device unusable and drains the mobile device battery.
- Fuzzing attacks
 - Sending malformed messages to the bluetooth device.
- Blue jacking
 - Uses IMEI identifier to route all the incoming calls.
- Blue snarfing
 - Causes harm when the user sends the data to the other user.



Scanning



```
BD Address: AC:C1:EE:1B:70:DD [mode 1, clkoffset 0x0f08]
OUI company: Xiaomi Communications Co Ltd (AC-C1-EE)
Device name: 小米手机
Device class: Phone, Smart phone (0x5a020c)
Manufacturer: Qualcomm (29)
LMP version: 4.2 (0x8) [subver 0x25a]
LMP features: 0xff 0xfe 0x8f 0xfe 0xd8 0x3f 0x5b 0x87
               <3-slot packets> <5-slot packets> <encryption> <slot offset>
               <timing accuracy> <role switch> <hold mode> <sniff mode>
               <RSSI> <channel quality> <SCO link> <HV2 packets>
               <HV3 packets> <u-law log> <A-law log> <CVSD> <paging schemes>
               <power control> <transparent SCO> <broadcast encrypt>
               <EDR ACL 2 Mbps> <EDR ACL 3 Mbps> <enhanced iscan>
               <interlaced iscan> <interlaced pscan> <inquiry with RSSI>
               <extended SCO> <AFH cap. slave> <AFH class. slave>
               <LE support> <3-slot EDR ACL> <5-slot EDR ACL>
               <sniff subrating> <pause encryption> <AFH cap. master>
               <AFH class. master> <EDR eSCO 2 Mbps> <extended inquiry>
               <LE and BR/EDR> <simple pairing> <encapsulated PDU>
               <non-flush flag> <LSTO> <inquiry TX power> <EPC>
               <extended features>
```

P.nbr.	Time (us)	Channel	Access Address	Adv PDU Type	Adv PDU Header				ScanA	AdvA	CRC	RSSI (dBm)	FCS
					Type	TxAdd	RxAdd	PDU-Length					
142	+3713629	0x25	0x8E89BED6	ADV_SCAN_REQ	3	1	1	12	0x55FD9507B149	0x7EC7D696772B	0x5D4ECC	-67	OK

Sniffing – 对广播信道的嗅探

- 使用德州仪器 (TI) CC2540蓝牙低功耗模块配合官方的SmartRF协议软件包监听器：PACKET-SNIFFER，可对三个蓝牙广播信道进行嗅探。



Texas Instruments SmartRF Packet Sniffer Bluetooth Low Energy

File Settings Help

P.nbr.	Time (us)	Channel	Access Address	Adv PDU Type	Adv PDU Header			AdvA	AdvData	CRC	RSSI (dBm)	FCS
					Type	TxAdd	RxAdd	PDU-Length				
1	+0 =0	0x25	0x8E89BED6	ADV_IND	0	1	0	6	0x45ACE4245A54	None	0xCF7BC2	-47 OK
2	+607 =607	0x25	0x8E89BED6	ADV_SCAN_RSP	4	1	0	6	0x45ACE4245A54	None	0xB1BB8	-47 OK
3	+1006847 =1007454	0x25	0x8E89BED6	ADV_IND	0	1	0	23	0x45ACE4245A54	02 01 02 09 FF C1 FF 1C 96 5A FF 4B E7 03 02 C1 FE	0xB8DD97	-34 OK
4	+1006203 =2013657	0x25	0x8E89BED6	ADV_IND	0	1	0	23	0x45ACE4245A54	02 01 02 09 FF C1 FF 1C 96 5A FF 4B E7 03 02 C1 FE	0xB8DD97	-42 OK
5	+1002454 =3016111	0x25	0x8E89BED6	ADV_IND	0	1	0	23	0x45ACE4245A54	02 01 02 09 FF C1 FF 1C 96 5A FF 4B E7 03 02 C1 FE	0xB8DD97	-43 OK
6	+1007454 =4023565	0x25	0x8E89BED6	ADV_IND	0	1	0	23	0x45ACE4245A54	02 01 02 09 FF C1 FF 1C 96 5A FF 4B E7 03 02 C1 FE	0xB8DD97	-42 OK

Capturing device | Radio Configuration | Select fields | Packet details | Address book | Display filter | Time line

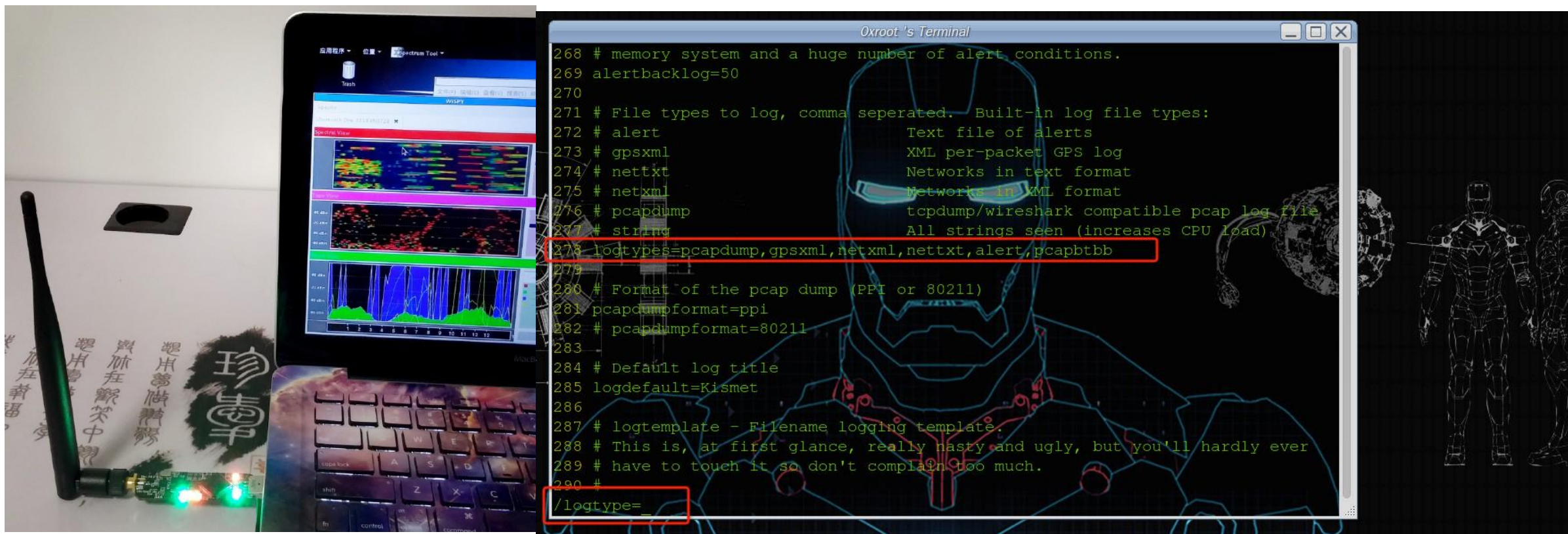
```

+-----+-----+
| Packet sniffer frame header |
+-----+-----+
|info| Packet nbr. | Time stamp | Length | Packet data |
+-----+-----+
| 01 | 03 00 00 00 | 9F 0C 79 CF 01 00 00 00 | 23 00 | 22 D6 BE 89 8E 40 17 54 5A 24 E4 AC 45 02 01 02 09 FF C1 FF 1C 96 5A FF 4B E7 03 02 C1 FE 97 DD B8 3C A5 |
+-----+-----+

```

Packet count: 418 | Error count: 45 | Filter off | RF device: CC2540 | Channel: 37 [0x25]

Sniffing – 对通信过程的嗅探



lib库

libbtbb

ubertooth

wireshark

kismet

BLE解密工具crackle

<https://github.com/mikeryan/crackle>

BLE - Replay Attack

- 用Light Blue来强制连接蓝牙设备
- 进入连接页面，可以看到该蓝牙设备更详细的信息，
- 连接小米手环进行重放攻击。



Breaking Secure Pairing of Bluetooth Low Energy Using Downgrade Attacks

Yue Zhang, Jian Weng, Rajib Dey, Yier Jin, Zhiqiang Lin, Xinwen Fu
USENIX Security Symposium. August 12–14, 2020

BLE-Guardian: Protecting the Privacy of BLE Users

Kassem Fawaz*, Kyu-Han Kim†, Kang G. Shin*

*Computer Science and Engineering, University of Michigan

†Hewlett Packard Labs

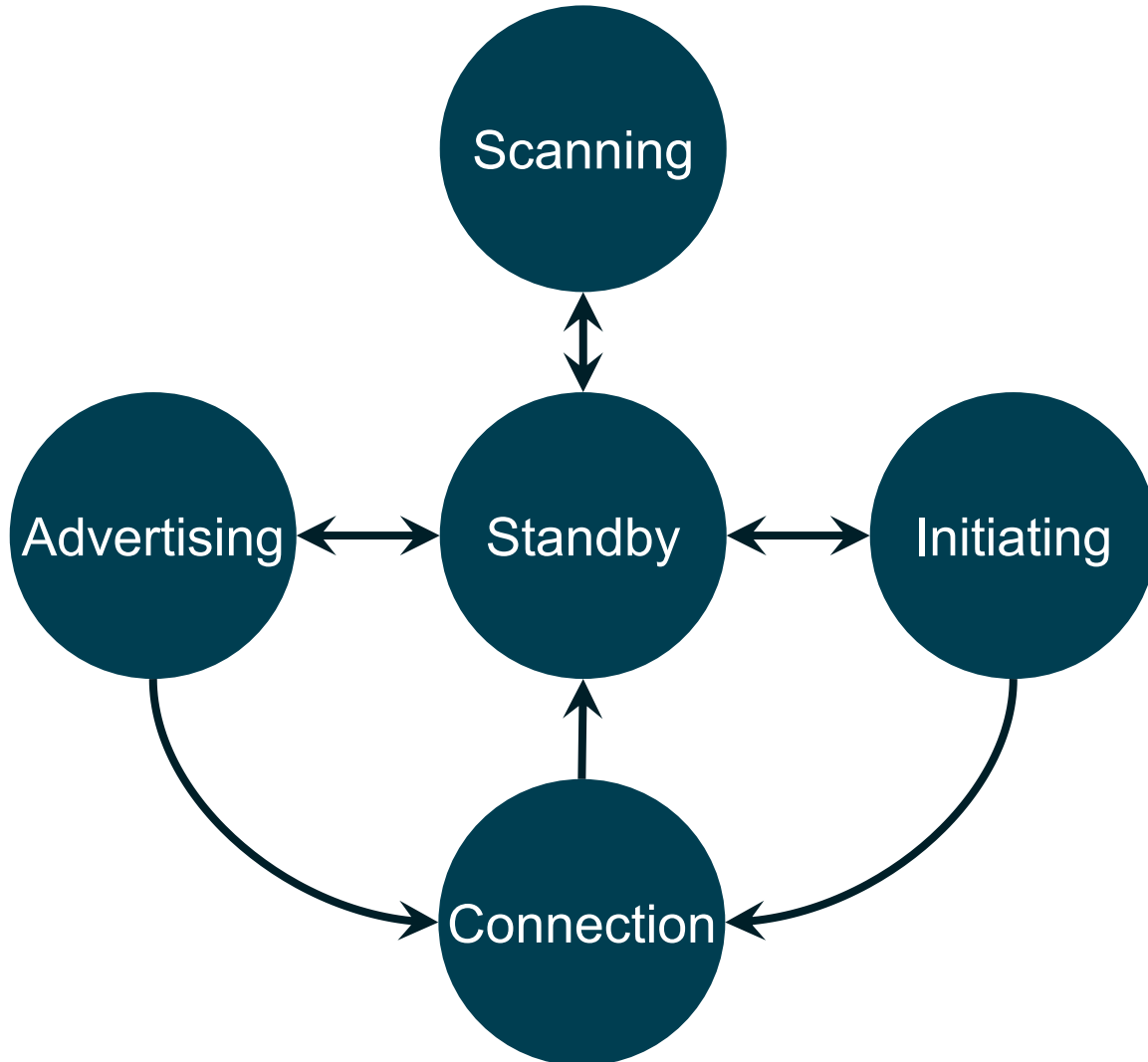
USENIX Security 2016

Bluetooth Low Energy

- Attractive communication technology
 - Short range
 - Low energy footprint
 - Supported by most hosts
- Currently:
 - 74K unique products with BLE support
- 2013:
 - 1.2 billion BLE products shipped
- 2020:
 - 2.7 billion BLE products expected



BLE Primer

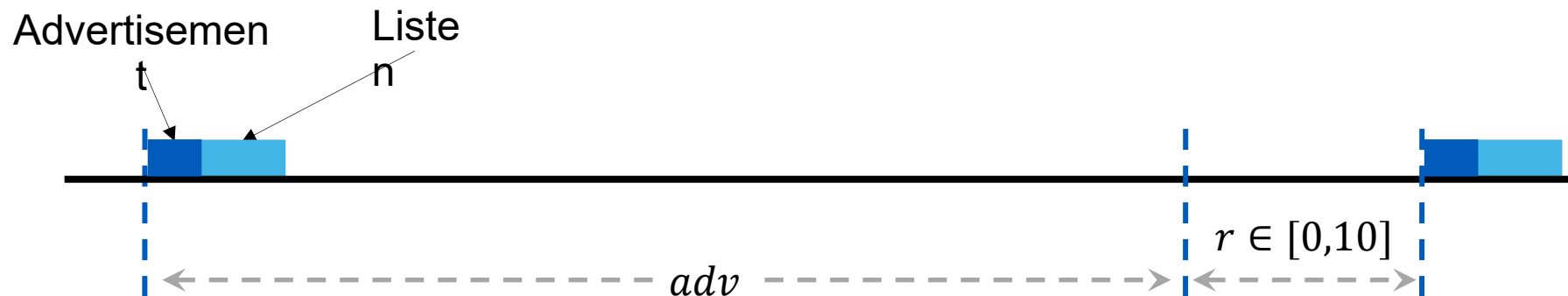


- **Standby:** Low Power Mode. Receiver and transmitter switched 'off'
- **Advertising:** Used by low power 'Server'. Only transmitter required.
- **Scanning:** Used by 'Client'. Receiver listens to advertising channels.
- **Initiating:** 'Server' sends connection request
- **Connection:** After scanning, 'Client' responds to 'Server' advertisement

BLE Advertisements

- 3 dedicated advertising channels:
 - 2402 MHz (37), 2426 MHz (38), 2480 MHz (39)

Type	Description	Frequency
ADV_DIRECT_IND	Connect to a particular device only	3.75 ms, but only for 1.28 seconds
ADV_IND	General presence known + connections	20ms – 10.24s



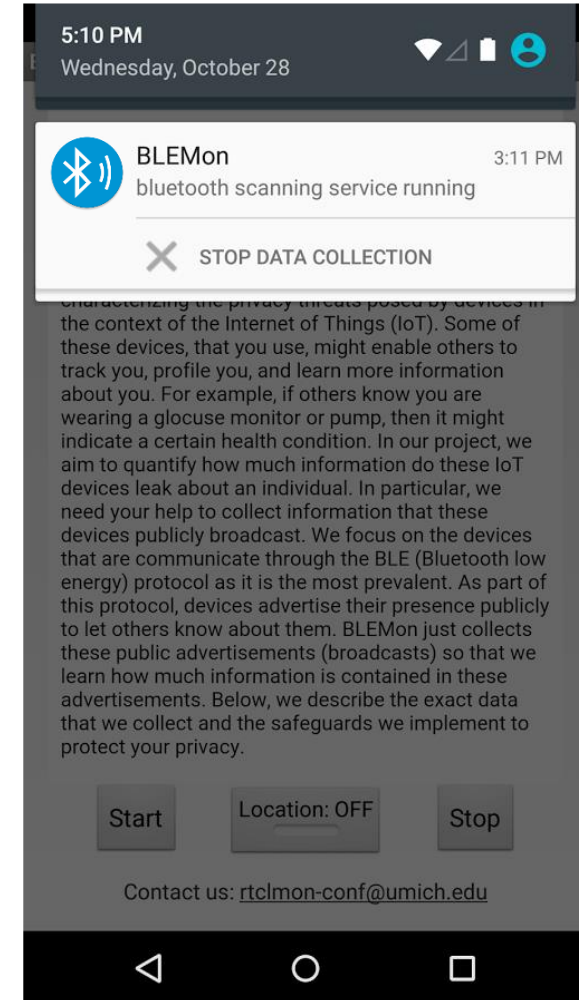
BLE Security and Privacy

- Pairing & bonding
 - Prevent unauthorized access to device or secured services
- Address randomization
 - Prevent user tracking
- Direct Advertisements
 - Prevent user tracking and profiling

BLE Privacy & Security Effectiveness

- *Passively* scan for BLE advertisements
- Collect:
<Timestamp, BT Address, advertisement content, RSSI>

Site	Participants	Period
Hewlett Packard Labs	1	40 days
Ann Arbor	13	2 months
Phone LAB/ SUNY Buffalo	86	2 months



BLE Privacy & Security Effectiveness

- Indirect Advertisements
 - Detected 214 different unique types of devices
- Address Randomization

Name	Description
ihere	key finder
DEXCOMRX	Glucose monitor
Frances's Band ea:9d	smartband
Otbeat	heart rate monitor
JS00002074	digital pen

Revealing Names

Device	Days observed
One	37
Flex	37
Zip	37
Forerunner 920	36
Basis Peak	25

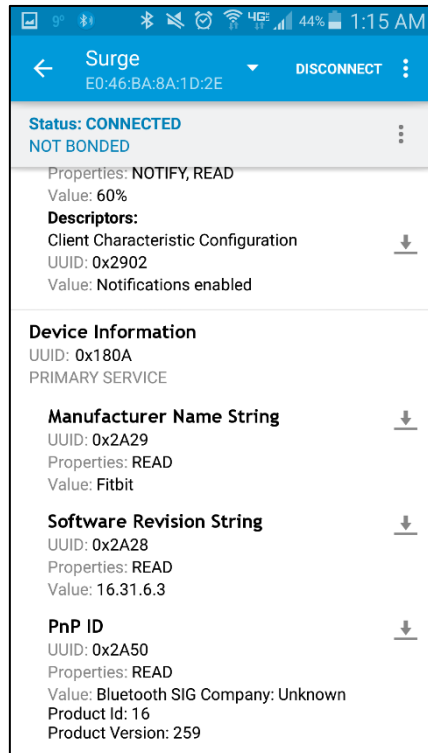
Consistent Addresses

Address
00:17:E9:CB:F3:6 1
00:17:E9:CB:F5:0 1

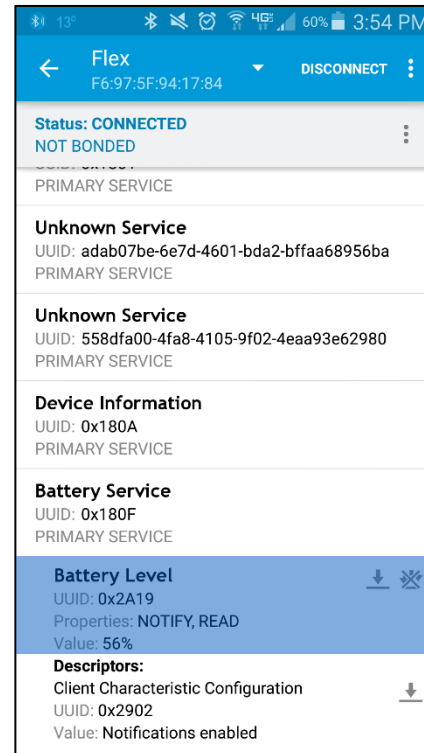
**Poor
Randomization**

BLE Privacy & Security Effectiveness

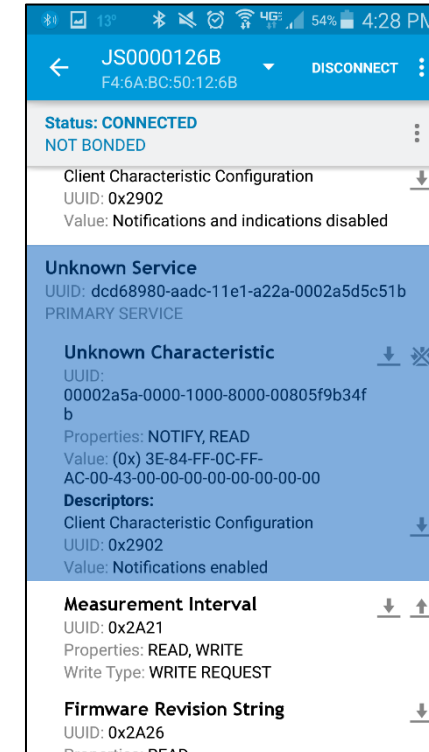
- Device paring



Advertise and accept connections

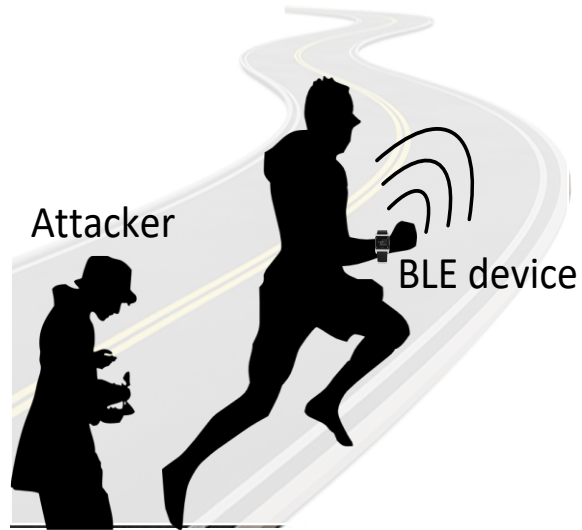


Battery level



Unique identifiers

It all starts with the advertisements...

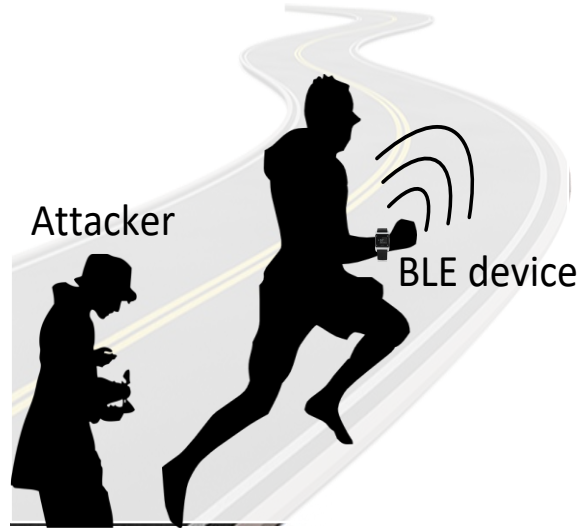


Tracking User

Consistent addresses, poor randomization, unique device names and identifiers

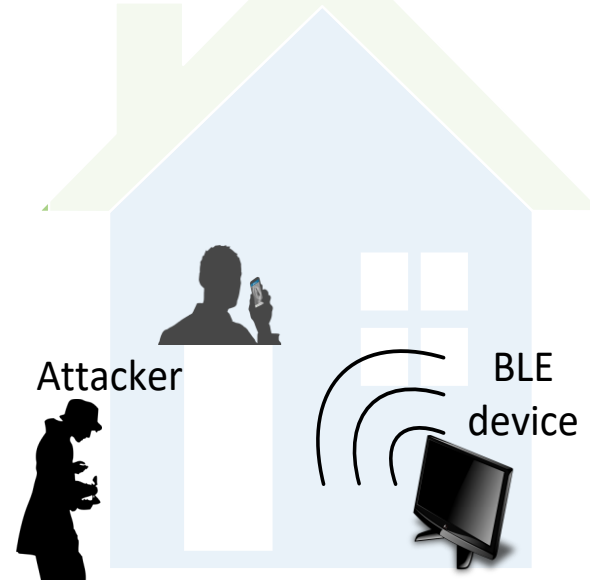


It all starts with the advertisements...



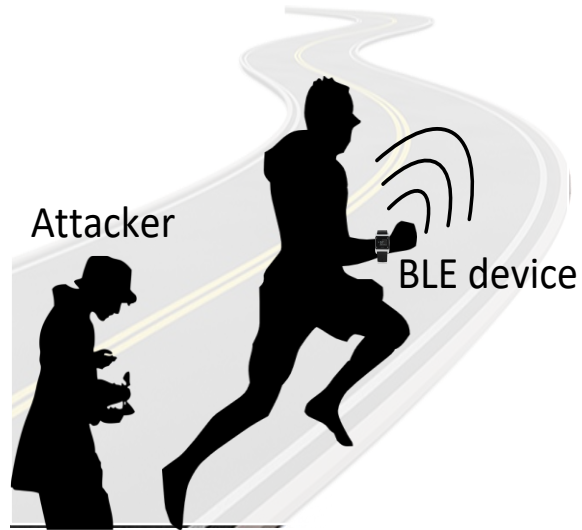
Tracking User

Health situation, user's lifestyle, behavior, preferences, and personal interests

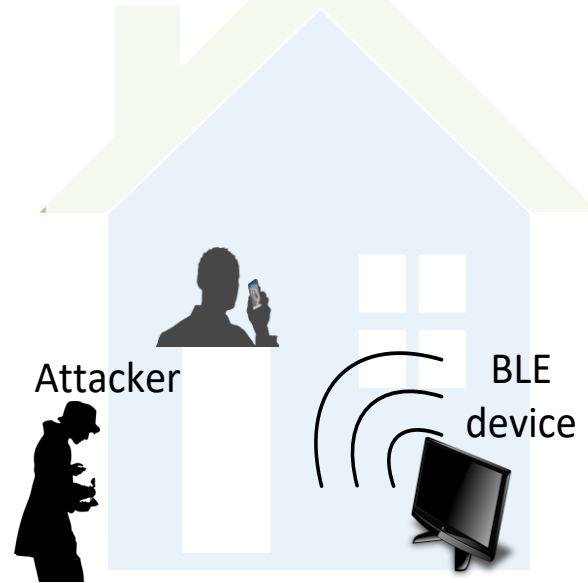


Profiling User

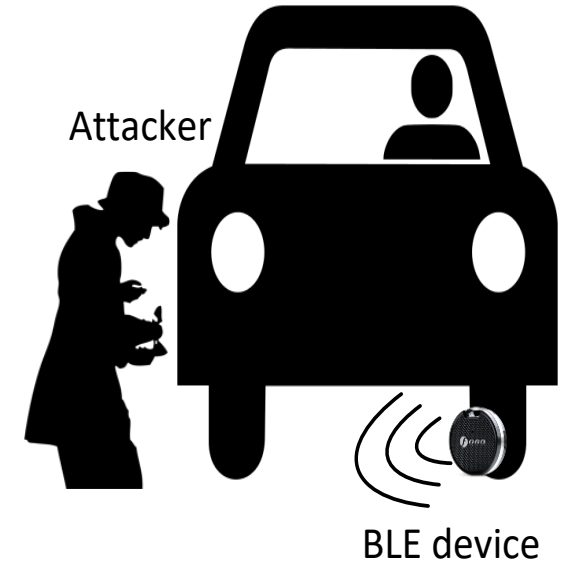
It all starts with the advertisements...



Tracking User



Profiling User



Harming User

Fingerprinting of and unauthorized access for sensitive systems and devices

Research Questions

- Can we effectively fend off the threats to BLE-equipped devices
 - in a device-agnostic manner,
 - using COTS (Commercial-Off-The-Shelf) hardware only, and
 - with as little user intervention as possible?

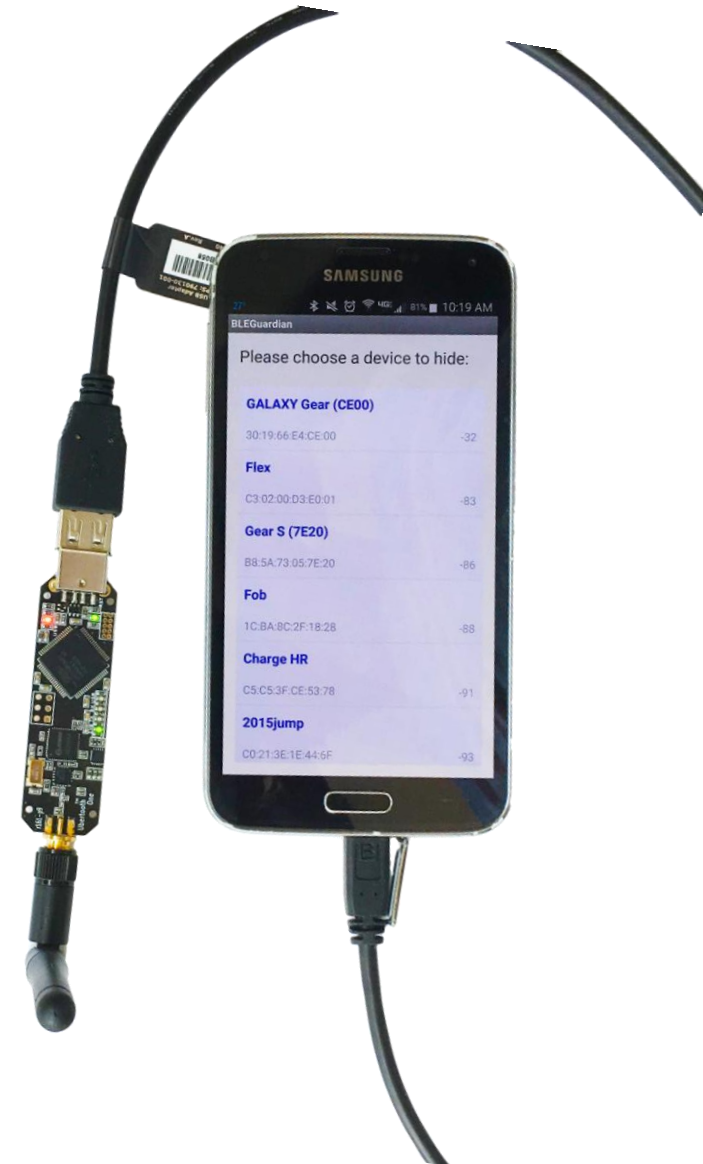


BLE-Guardian

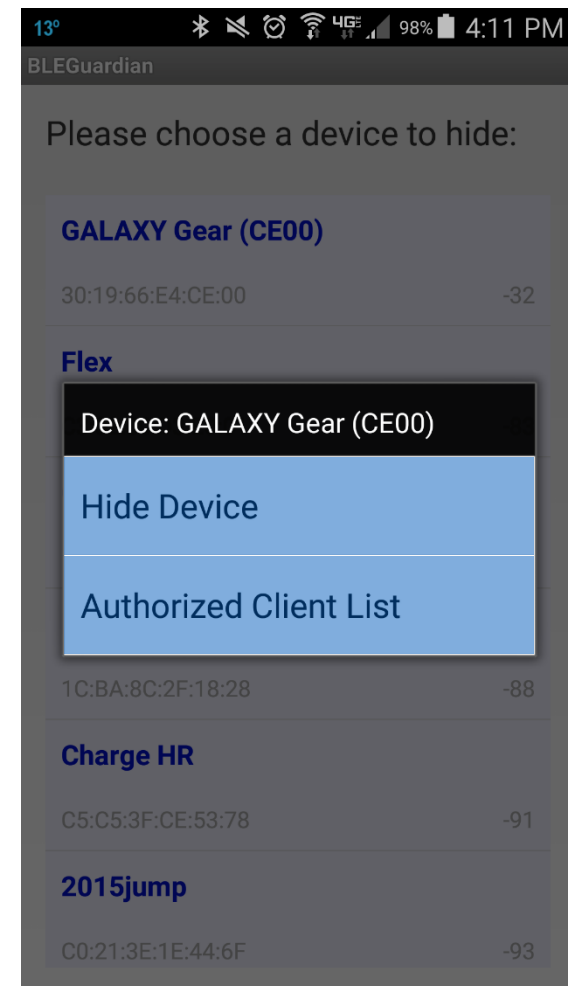
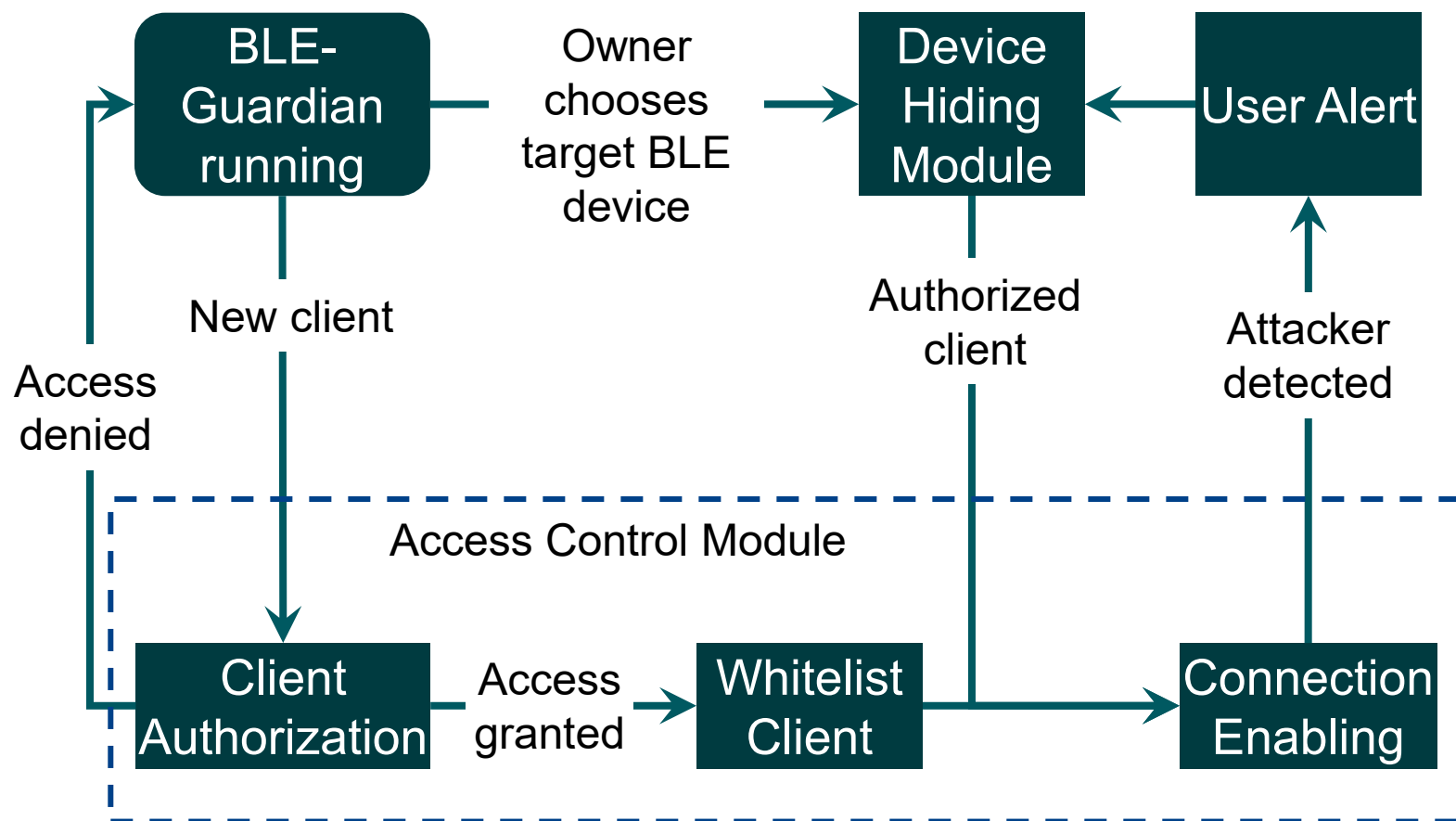


BLE-Guardian

- Ubertooth One
 - Programmable BT radio
 - Open source firmware
 - Rx/Tx on each BT channel
- User-level app
 - Control BLE-Guardian
 - Update firmware seamlessly

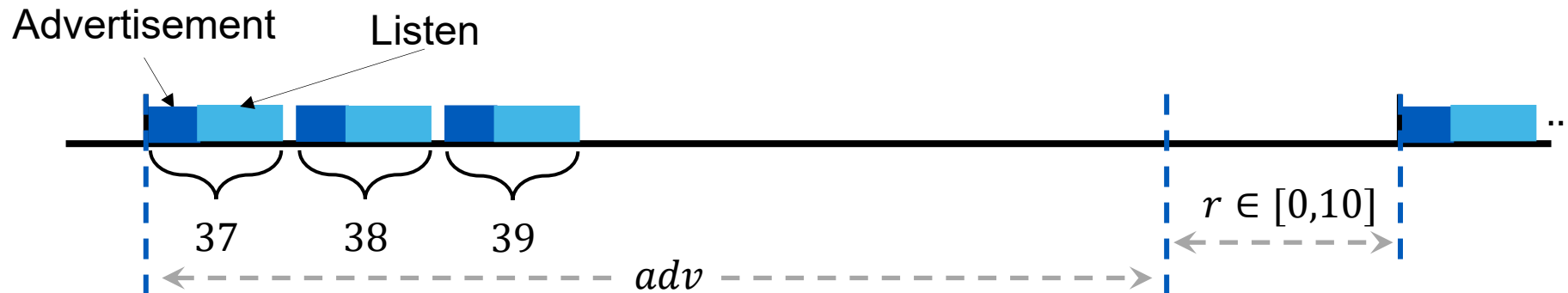


High-level Description



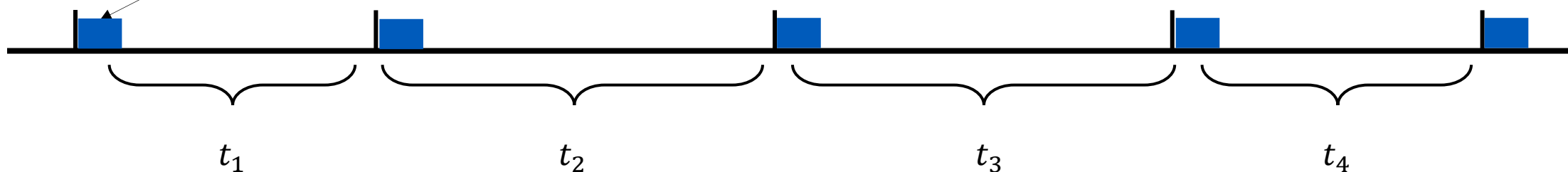
Device Hiding

- Jam BLE device advertisements to hide its existence
 - Need to learn device advertising Sequence
 - Otherwise jamming will be ineffective or inefficient



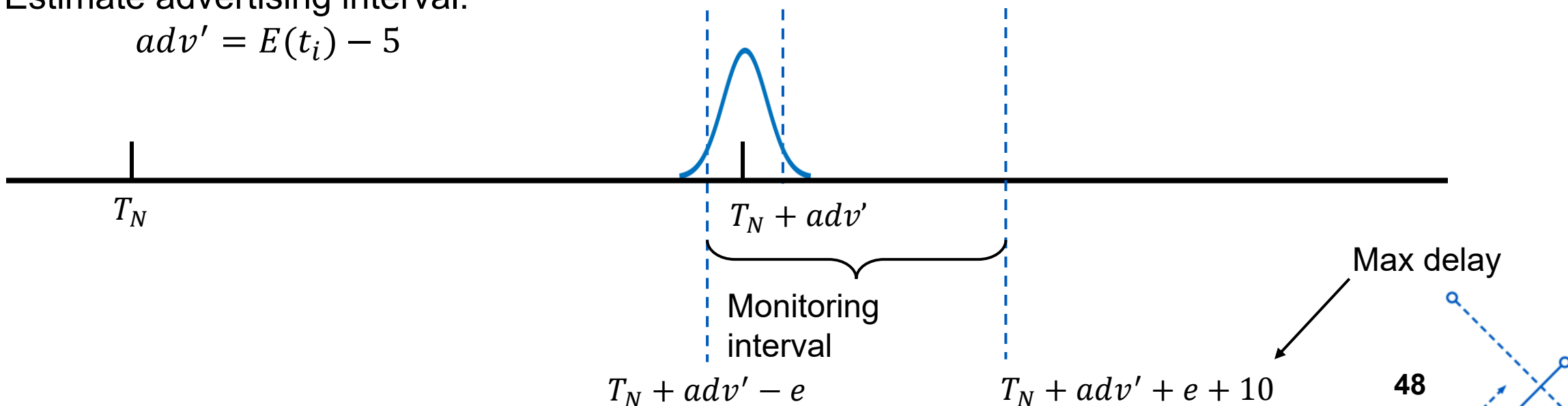
Device Hiding

Advertisement session

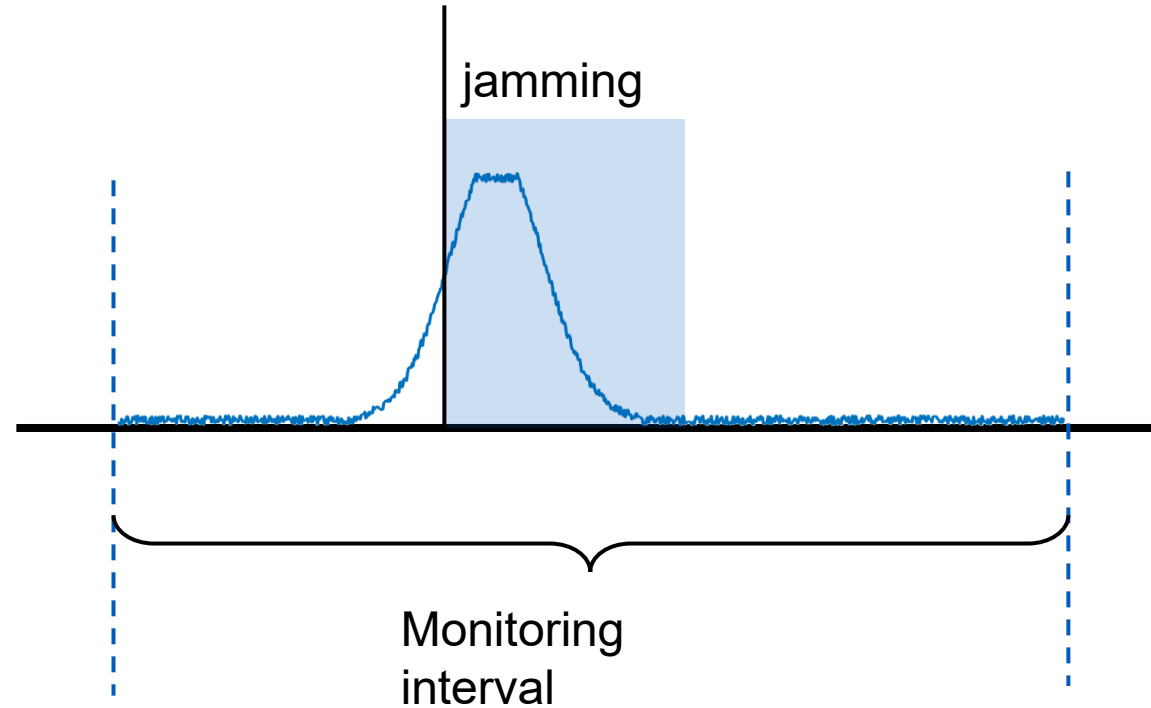


Estimate advertising interval:

$$adv' = E(t_i) - 5$$



Device Hiding



- Detect RSSI (received signal strength indication) increase
- Apply jamming and follow advertising sequence



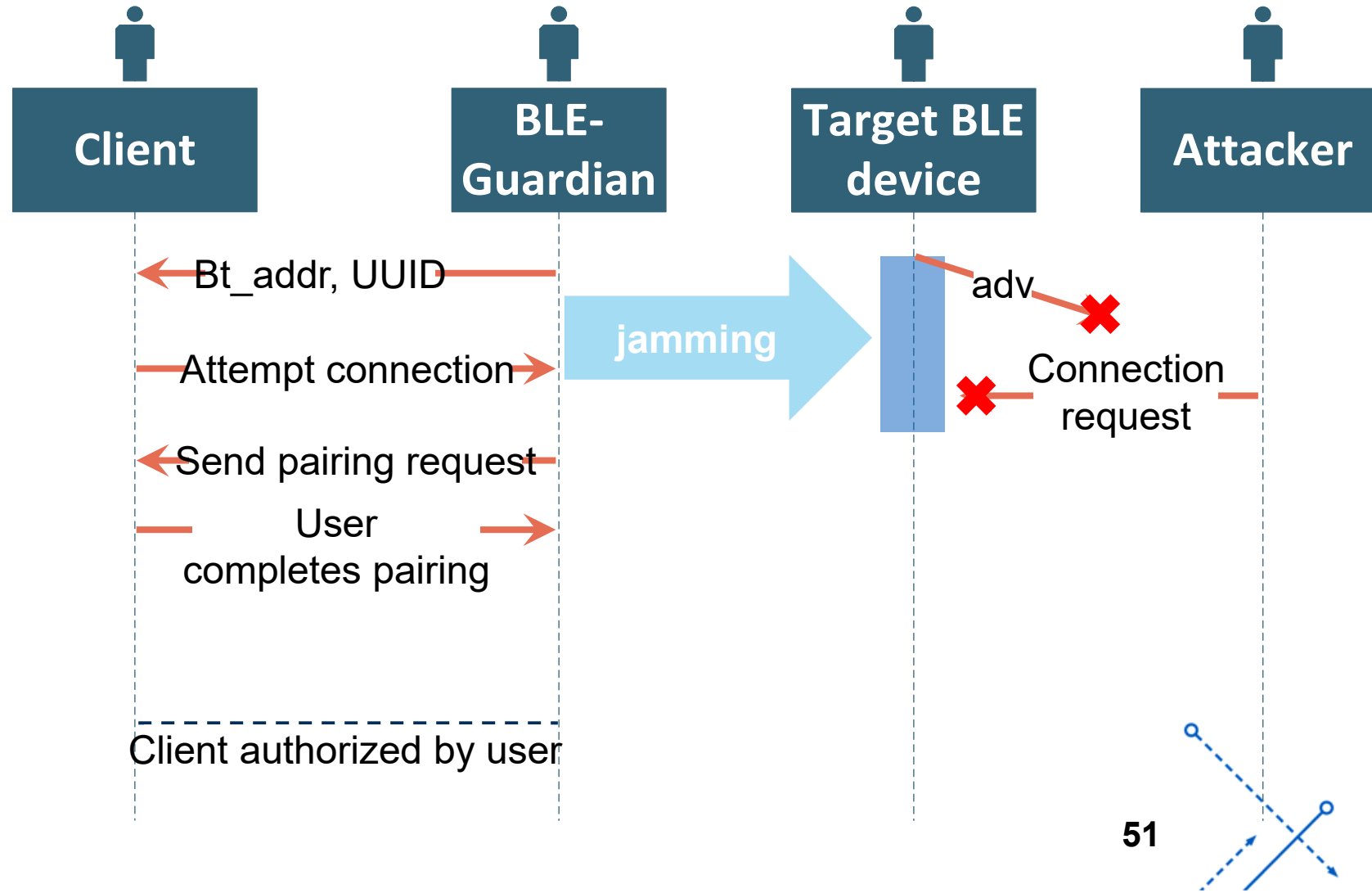
At this point, the target BLE device is hidden.

How to enable access to it?

Access Control

Authorization:

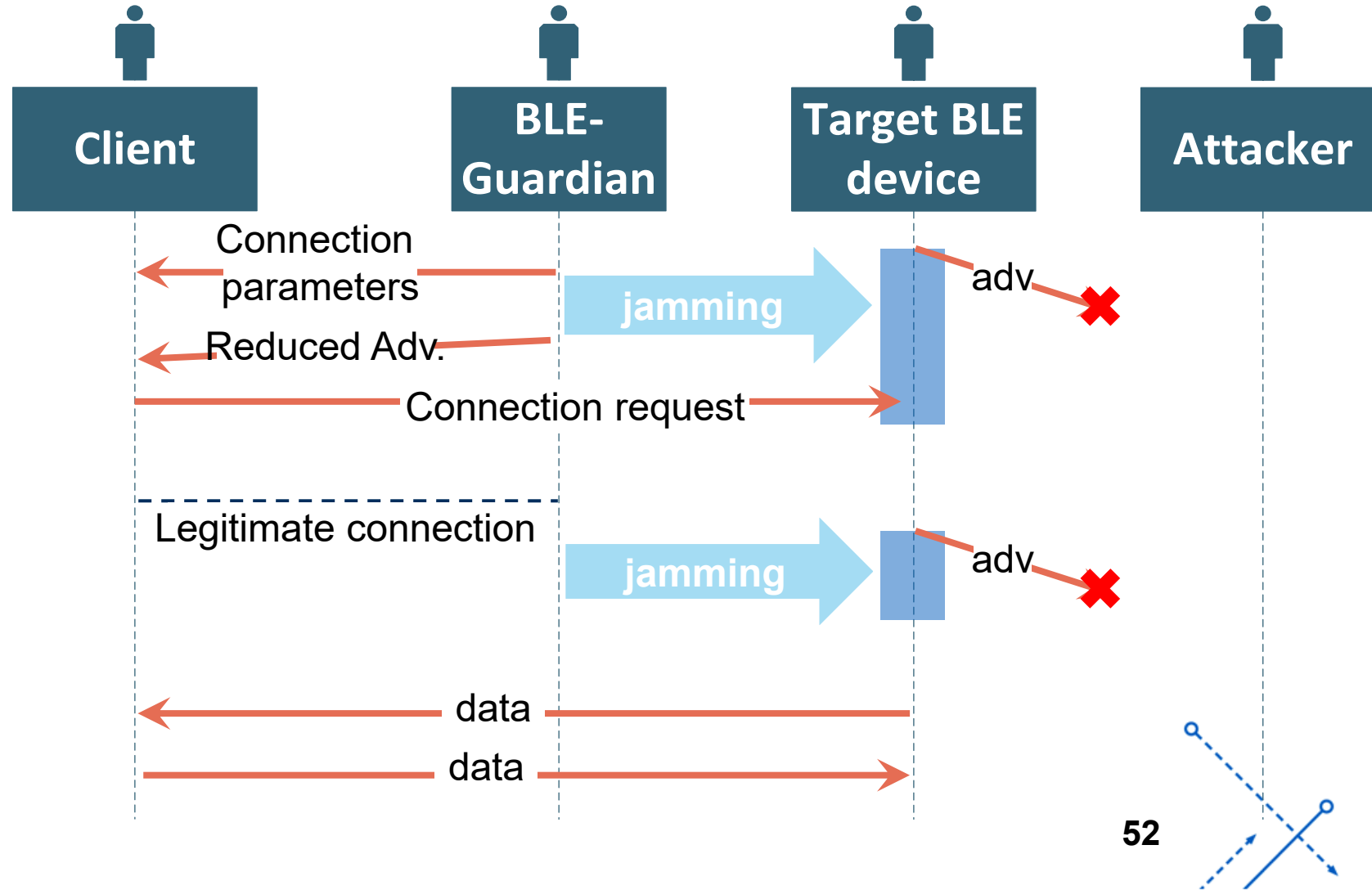
Bluetooth classic as an
OOB channel.



Access Control

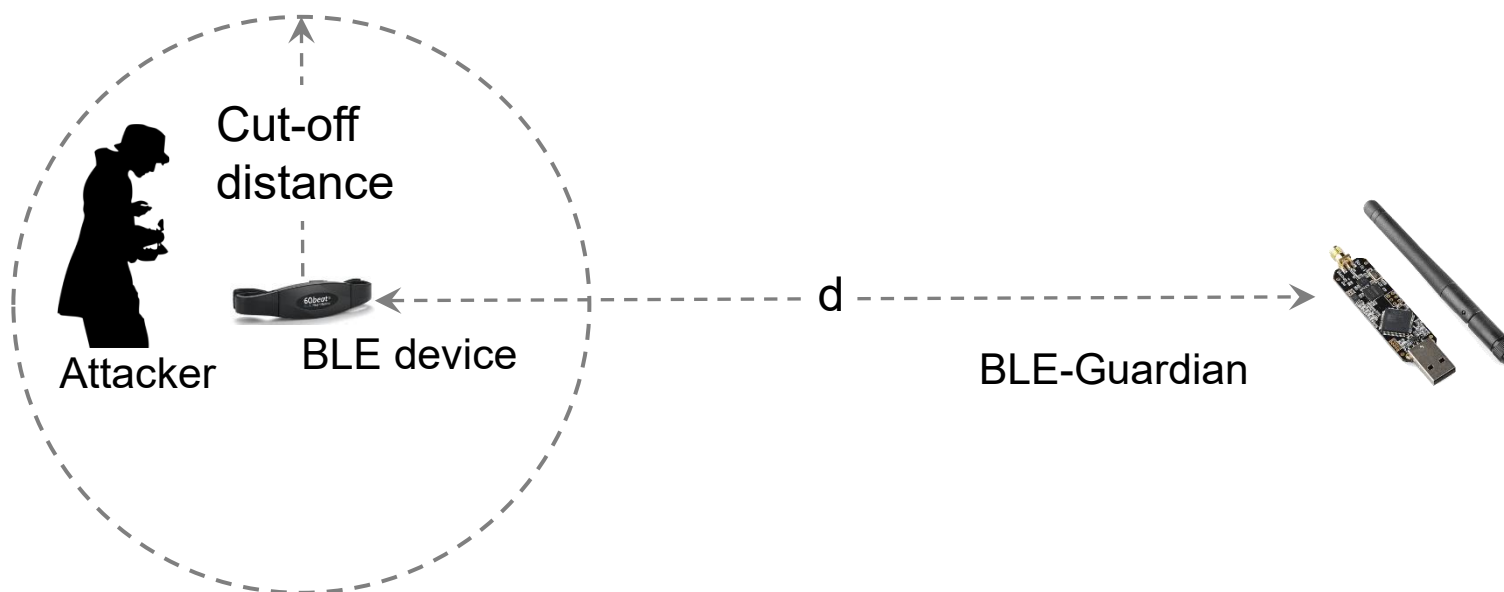
Connection Enabling:

Connection parameters to distinguish legitimate connection request.



Evaluation

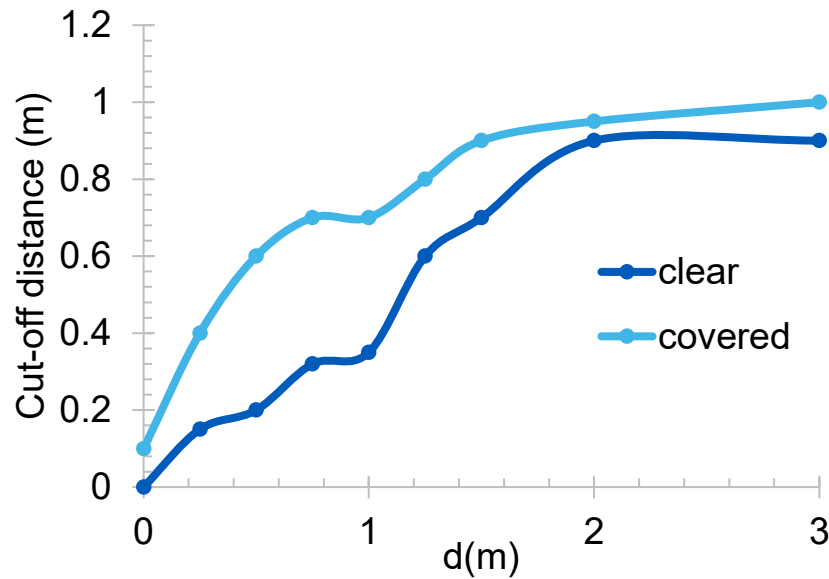
- Cut-off Distance



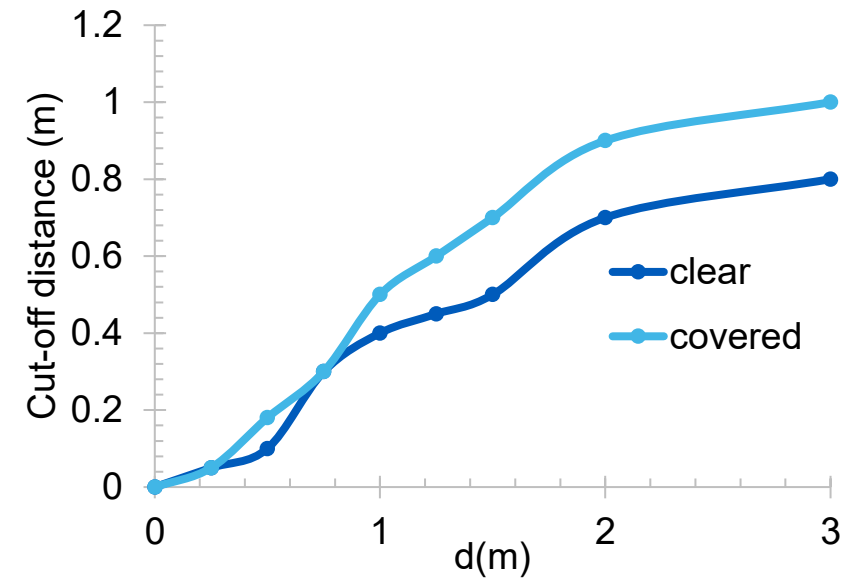
Evaluation

- Cut-off Distance

TI CC2540



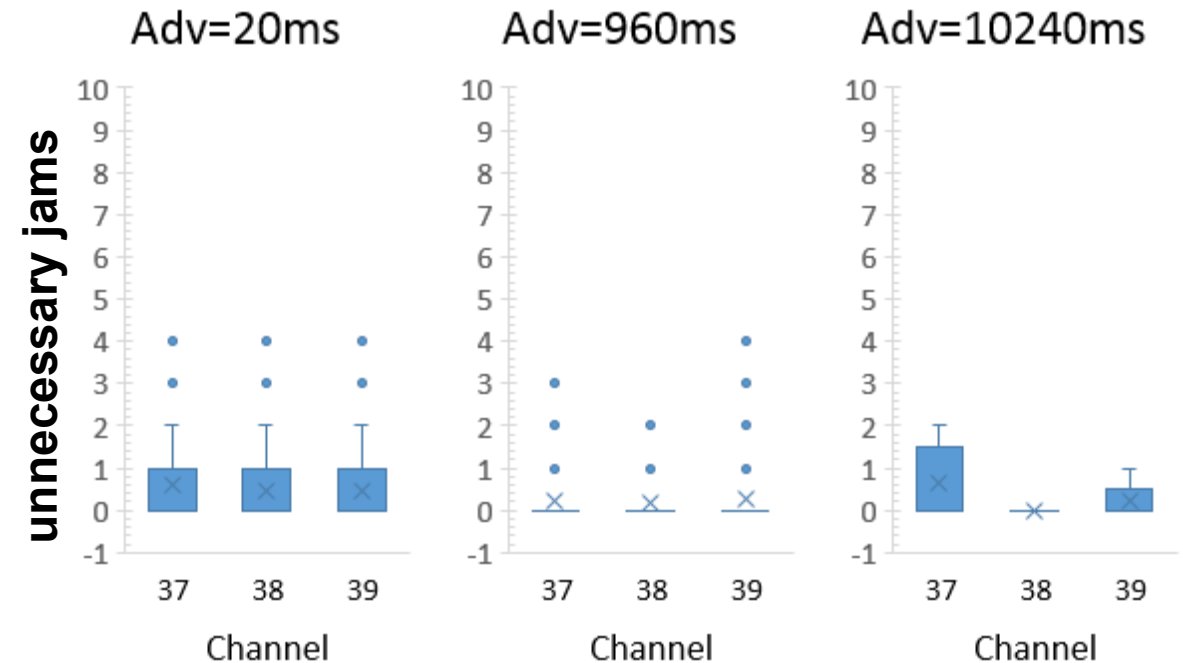
Galaxy S5



Adversary has to be within 1 m of BLE device to read its advertisements

Evaluation

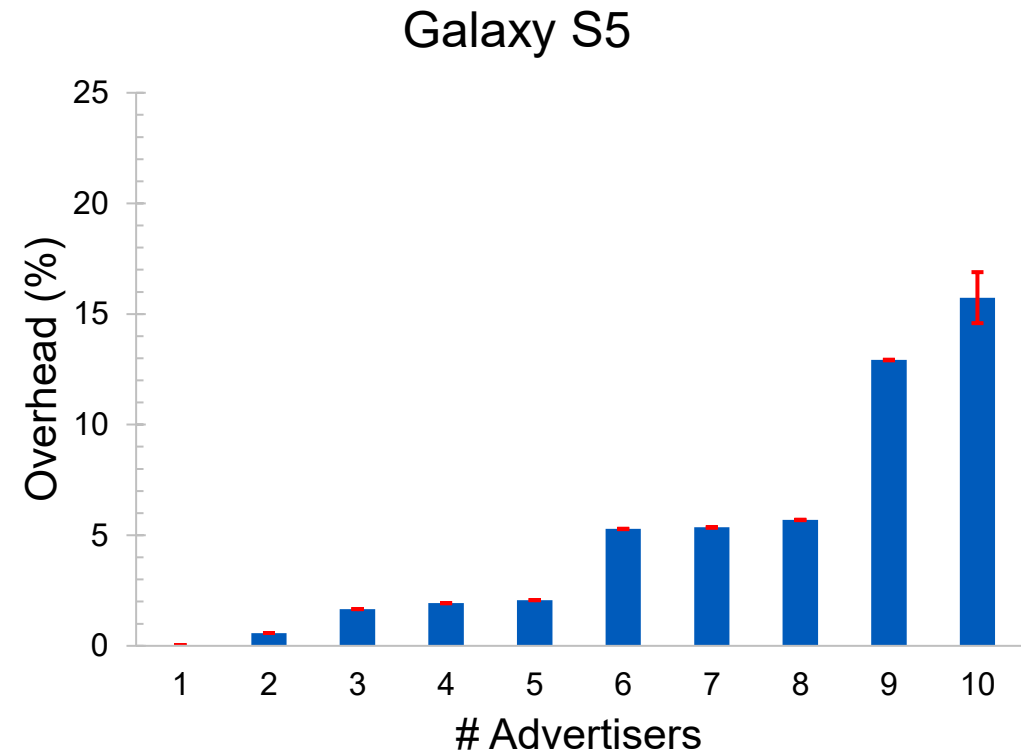
- Impact on Advertising Channels
 - Protect single device at advertising intervals:
 - 20ms, 960ms, and 10.24 sec
 - Two devices advertising at 20 ms
 - 15 other devices
 - With varying advertising frequencies



The number of unnecessary jamming instance is minimal

Evaluation

- Energy Overhead
 - BLE-device and authorized clients
 - No overhead
 - Smartphone as a gateway
 - Idle power: 1370mW
 - Overhead: less than 16%



Acknowledgement

- Slides are adapted from talks given by:
 - Scott Anson from University of Washington: “Bluetooth Security”
 - Jaymin Shah: “An Analysis of Bluetooth Security”
 - Kassem Fawaz from University of Michigan: “BLE-Guardian: Protecting the Privacy of BLE Users”